Spec Sheet: lokaler Client (Tally32 Agent)

Funktionsumfang, Berechtigungen und Risikobeurteilung

Ansprechperson	Oliver Timme
Abteilung / Arbeitsplatz	
Betriebsart	Standalone: ein Display pro Arbeitsplatz, der Agent läuft auf dem eigenen Windows-Rechner unter dem eigenen Benutzerkonto
Funktionsumfang	Statusanzeige **und Terminbuchung am Display** (beides Kernfunktionen), dafür das Recht Calendars.ReadWrite
Stand der Angaben	10/2026, Agent und Firmware Version 1.1, gemäss Quellcode. Auf Windows 11 erprobt.

1. Zweck

Tally32 ist eine kleine Statusanzeige am Arbeitsplatz (Display mit 7 oder 10,1 Zoll, per USB angeschlossen). Sie zeigt Kolleginnen, Kollegen und Besuchern, ob man gerade **telefoniert** (ON AIR), **besetzt** ist und **ab wann man wieder frei** ist, oder ob man nicht am Platz ist. Zweite Kernfunktion ist die **Terminbuchung**: Wer den Benutzer nicht am Platz antrifft, reserviert direkt am Display einen freien Termin und erhält eine Einladung. Der Agent ist das Programm auf dem Rechner, das diese Informationen ermittelt und per USB-Kabel an das Display schickt.



Keine eingehenden Verbindungen, kein offener Port, keine Daten an Dritte.

2. Was der Agent macht

Funktion	Quelle	Daten, die gelesen werden	Intervall
Anruf erkennen	Windows-Registry (HKCU), nur lesen: Mikrofon-Nutzungsanzeige von Windows (CapabilityAccessManager, ConsentStore microphone)	nur ob eine App gerade das Mikrofon benutzt und welche (z. B. Teams, 3CX). **Keine Audiodaten.**	2 s
Bildschirmsperre	Windows-API WTSQuerySessionInformation	nur gesperrt ja oder nein	2 s
Teams-Status	Microsoft Graph GET /me/presence	Verfügbarkeit und Aktivität (z. B. Busy, InACall)	10 s
Kalender	Microsoft Graph GET /me/calendarView, heute und morgen	nur **Beginn, Ende, Frei/Gebucht-Status, abgesagt** (Feldauswahl $select=showAs,start,end,isCancelled,isAllDay). Kein Betreff, kein Ort, keine Teilnehmer, kein Inhalt.	60 s
Abwesenheit	Microsoft Graph GET /me/mailboxSettings	Abwesenheitsnotiz: an/aus, Zeitraum, Text (wird angezeigt, abschaltbar)	120 s
Terminbuchung (Kernfunktion)	Microsoft Graph GET /me/calendarView (2 Wochen) und POST /me/events	liest dieselben Zeitfelder. Legt auf Anfrage vom Display einen Termin im eigenen Kalender an, mit Titel und E-Mail-Adresse, die der Besucher eingegeben hat. Exchange verschickt dabei die Einladung an den Besucher.	nur bei Buchung
Ausgabe ans Display	USB-Seriell (COM-Port, 115200 Baud)	Status, Uhrzeit, «frei ab» bzw. «frei bis», Terminblöcke von heute und morgen (nur Zeiten), Name des Kontos	2 bis 30 s

3. Was der Agent nicht macht

- **Keine Audio- oder Videoaufnahme.** Er öffnet weder Mikrofon noch Kamera, er liest nur die Windows-Anzeige, ob sie benutzt werden.
- **Liest keine E-Mails, Kontakte, Dateien, Chats** und keine Betreffs, Orte, Teilnehmer oder Inhalte von Terminen.
- **Nur das eigene Postfach** (/me). Kein Zugriff auf Kalender oder Status anderer Personen.
- **Keine eingehenden Verbindungen**, kein offener Port, kein Webserver auf dem Rechner.
- **Ausgehend nur** login.microsoftonline.com und graph.microsoft.com (HTTPS 443). Keine Telemetrie, keine Daten an Dritte oder an den Entwickler.
- **Keine Administratorrechte**, kein Windows-Dienst, keine eigenen Treiber, keine Änderungen an System- oder Sicherheitseinstellungen.
- **Keine Tastatur- oder Bildschirmaufzeichnung**, keine Fernsteuerung.
- **Führt nichts aus, was vom Display kommt.** Er versteht nur vier feste Textmeldungen: Anmeldung starten, freie Zeiten abfragen, Termin buchen, Protokollzeile. Alles andere wird ignoriert.
- **Das Display meldet sich nur als COM-Port.** Windows sieht einen COM-Port und die JTAG-Debugschnittstelle des Display-Chips, keine Tastatur (HID) und keinen Massenspeicher. Der Chip des Displays (ESP32-P4) könnte an diesem Anschluss grundsätzlich auch als anderes USB-Gerät auftreten (USB-OTG). Die Tally32-Firmware schaltet das nicht ein.

4. Technische Angaben

Merkmal	Angabe
Programm	Python-Skript agent/tally_agent.py (Quellcode einsehbar), Python 3.11 oder neuer. Alternativ als einzelne .exe verpackbar (PyInstaller), falls Python nicht erlaubt ist.
Abhängigkeiten	msal und msal-extensions (Microsoft Authentication Library, von Microsoft) und pyserial, aus PyPI. msal bringt requests, cryptography und PyJWT mit. Alle Versionen sind in agent/requirements.txt fest vorgegeben (z. B. msal==1.39.0).
Ausführung	im Benutzerkontext, unsichtbar (pythonw.exe), gestartet über die Aufgabenplanung «bei Anmeldung», Aufgabe «Tally32 Agent». Eingerichtet mit install_windows.ps1 ohne erhöhte Rechte.
Dateien	Programm und Python-Umgebung im Projektordner. Einstellungen in %USERPROFILE%\.config\tally32\config.json. Anmeldetoken mit **Windows DPAPI verschlüsselt** in token_cache.bin daneben, nur unter dem eigenen Benutzerkonto lesbar (macOS: Schlüsselbund). Ein Token aus einer älteren Version wird beim Start übernommen und die unverschlüsselte Datei gelöscht. Log in %LOCALAPPDATA%\tally32\tally32.log (Statusänderungen und Buchungen mit Datum, Zeit, E-Mail-Adresse und Titel des Besuchers).
USB-Gerät	GUITION JC1060P470C 7" oder GUITION JC8012P4A1C 10,1" (beide ESP32-P4), eingebaute USB-Schnittstelle des Chips (USB-Serial/JTAG, USB-VID 303A, PID 1001): COM-Port und JTAG-Debugschnittstelle des Displays. Treiber in Windows enthalten.
Netzwerk	ausgehend HTTPS 443 zu login.microsoftonline.com und graph.microsoft.com. Bei der Einrichtung einmalig pypi.org für die Pakete (entfällt mit der .exe).
Last	sehr gering: rund 7 kleine HTTPS-Abfragen pro Minute, wenige MB RAM.

5. Berechtigungen in Microsoft 365

Recht (delegiert)	Wozu	Nötig
Calendars.ReadBasic	Frei/Gebucht-Zeiten des eigenen Kalenders. Kleinstes Leserecht für calendarView laut Microsoft, gibt keinen Termintext und keine Anhänge frei. Der Agent fordert davon nur die Zeitfelder an. Keine Admin-Zustimmung nötig.	ja
Presence.Read	eigener Teams-Status	optional (abschaltbar)
MailboxSettings.Read	Abwesenheitsnotiz: Status, Zeitraum, Text. Kein Zugriff auf E-Mails.	optional (abschaltbar)
Calendars.ReadWrite	Terminbuchung am Display: Termin im eigenen Kalender anlegen, mit Einladung an den Besucher. Kernfunktion, im Agenten eingeschaltet ("booking": true).	ja

Anmeldung per Device Code mit dem eigenen Konto, delegiert, also nie mehr Rechte als der Benutzer selbst hat. Standardmässig über den öffentlichen Microsoft-Client «Microsoft Graph Command Line Tools» (App-ID 14d82eec-204b-4c2f-b7e8-296a70dab67e). Auf Wunsch der ICT stattdessen über eine eigene App-Registrierung des Tenants (nur die App-ID wird geändert). Dafür braucht es einmal die Zustimmung eines Admins (Abschnitt 10).

6. Das Display

- speichert **kein Microsoft-Token** und keine Kalenderinhalte, nur die Terminblöcke von heute und morgen (Zeiten ohne Text, höchstens 16 Stunden gültig), damit es auch abgedockt weiter anzeigt.

- spannt für die Einrichtung ein **eigenes WLAN** auf (Tally32-XXXX, WPA2 mit Passwort) mit passwortgeschütztem Webinterface. Dieses WLAN hat keine Verbindung ins Firmennetz und kein Internet. Gespeichert sind dort nur Einstellungen, das WLAN-Passwort und der Hash des Web-Passworts. Das Einrichtungs-WLAN lässt sich im Webinterface oder im Menü am Display **abschalten**. Wieder einschalten geht nur am Gerät selbst (Einstellungsmenü mit PIN oder 5 Sekunden aufs Display drücken).
- zeigt am Platz nur Status und Zeiten, **nie Betreffs** von Terminen, aber den Text einer aktiven Abwesenheitsnotiz.

7. Risikobeurteilung

Risiko	Eintritt	Auswirkung	Massnahmen	Rest
Schadsoftware unter dem Benutzerkonto liest das Anmeldetoken	gering	mittel: eigener Kalender lesbar, mit Buchung auch beschreibbar, bis zum Widerruf	Token mit Windows DPAPI verschlüsselt (nur unter dem eigenen Konto lesbar), nur delegierte Rechte, jederzeit in Entra widerrufbar. Schreibrecht nur auf den eigenen Kalender, jede Buchung im Log des Agenten nachvollziehbar.	gering
Missbrauch der Buchung am Display (unerwünschte Termine oder Einladungen)	mittel	gering	nur freie Zeiten im eingestellten Zeitfenster, höchstens 4 Buchungen pro Stunde, Einladung nur an die eingegebene Adresse. Zeitfenster, Wochentage und Mittagspause im Setup. Jede Buchung steht im Kalender und im Log, die Funktion lässt sich bei Bedarf am Display abschalten.	gering
Zusätzliches WLAN im Büro durch das Display	sicher	gering	WPA2 mit eigenem Passwort, kein Routing ins Firmennetz, Webinterface mit Passwort und Pflicht-Passwortwechsel. Einrichtungs-WLAN im Webinterface abschaltbar, wieder einschalten nur am Gerät.	gering
Manipuliertes Display oder USB-Gerät	gering	gering	Agent nimmt nur vier feste Textmeldungen an, keine Codeausführung. Das Display meldet sich nur als COM-Port und JTAG-Schnittstelle, keine Tastatur. Eine andere Firmware könnte das ändern, das setzt aber physischen Zugriff auf das Display voraus.	gering
Abhängigkeiten aus PyPI (Lieferkette)	gering	mittel	nur drei verbreitete Pakete (msal und msal-extensions von Microsoft, pyserial). Alle Versionen inklusive indirekter Pakete festgeschrieben, wahlweise eine geprüfte .exe.	gering
Anmeldung per Device Code (bekanntes Phishing-Muster)	gering	gering	Anmeldung startet nur der Benutzer selbst, das Token landet auf dem eigenen Rechner. Sperrt Conditional Access den Device Code Flow, ist eine eigene App-Registrierung nötig.	gering
Datenschutz: Verfügbarkeit sichtbar am Platz	beabsichtigt	gering	nur Status und Zeiten, keine Betreffs, entspricht dem Teams-Status. Text der Abwesenheitsnotiz wie für jeden Absender. Im Bildschirmschoner ist nur das Logo zu sehen.	gering

Gesamtbeurteilung: geringes Risiko. Der Agent arbeitet mit den Rechten des Benutzers, liest nur Zeiten und Status des eigenen Kontos, öffnet keine Ports und spricht nur mit Microsoft. Geschrieben wird nur für die Terminbuchung und nur in den eigenen Kalender. Das Token liegt verschlüsselt im Benutzerprofil.

8. Schutzmassnahmen und Hinweise für den Betrieb

- Anmeldetoken verschlüsselt ablegen (Windows DPAPI). *Umgesetzt.*
- Paketversionen festschreiben (agent/requirements.txt). *Umgesetzt.*
- Einrichtungs-WLAN des Displays mit eigenem Passwort versehen und nach der Einrichtung abschalten (Webinterface, Abschnitt Einrichtungs-WLAN). *Umgesetzt.*
- Wahlweise eigene App-Registrierung des Tenants statt des öffentlichen Microsoft-Clients.
- In einer allfälligen USB-Gerätekontrolle nur das Gerät VID 303A / PID 1001 freigeben, und dort nur die Klassen COM-Port (CDC) und JTAG, keine Tastatur (HID).

9. Widerruf und Deinstallation

- Anmeldung löschen: `tally_agent.py logout` (löscht das gespeicherte Token).
- Zugriff serverseitig sperren: in Entra die Anmeldesitzungen des Benutzers widerrufen oder die Zustimmung für die App entfernen.

- Entfernen: `install_windows.ps1 -Uninstall` (Aufgabe und Prozess), danach Projektordner und %USERPROFILE%\.config\tally32 löschen.

10. Warum einmal eine Admin-Freigabe nötig ist

Auf dem Rechner braucht der Agent **keine Adminrechte**. Einmalig nötig ist aber eine **Zustimmung (Consent) in Microsoft Entra ID**, damit der Agent im Namen des Benutzers auf dessen eigenen Kalender und Teams-Status zugreifen darf.

Was	Administratorzustimmung für die App «Microsoft Graph Command Line Tools» (oder eine eigene App-Registrierung) mit den delegierten Rechten Calendars.ReadBasic, Calendars.ReadWrite, Presence.Read und MailboxSettings.Read
Warum	Viele Tenants erlauben Benutzern nicht, Apps selbst zuzustimmen, und Schreibrechte auf den Kalender gibt meist nur ein Admin frei. Ohne Zustimmung bricht die Anmeldung mit «Administratorgenehmigung erforderlich» ab.
Wie oft	einmalig. Danach meldet sich der Benutzer selbst an, der Agent erneuert seine Tokens ohne weitere Freigabe.
Was sie nicht bedeutet	keine Adminrechte auf dem Rechner, kein Zugriff auf andere Postfächer (delegiert, nur das eigene Konto), keine Anwendungsberechtigung (App-only), kein Zugriff auf E-Mails, Dateien oder Chats
Eingrenzen	Die Zustimmung lässt sich auf diesen einen Benutzer beschränken statt auf die ganze Organisation (OAuth2-Berechtigung mit consentType Principal, siehe unten). Alternativ eine eigene App-Registrierung, die nur diesem Benutzer zugewiesen ist.
Rückgängig	in Entra unter Unternehmensanwendungen die Berechtigung entfernen, gilt sofort

Zustimmung nur für einen Benutzer (Microsoft Graph PowerShell, Platzhalter ersetzen):

```
New-MgOauth2PermissionGrant -BodyParameter @{
  clientId    = "<Objekt-ID Service Principal der App>"
  consentType = "Principal"
  principalId = "<Objekt-ID des Benutzers>"
  resourceId  = "<Objekt-ID Service Principal Microsoft Graph>"
  scope       = "Calendars.ReadBasic Calendars.ReadWrite Presence.Read MailboxSettings.Read"
}
```

11. Auf einen Blick

Punkt	Angabe
Programm	Tally32 Agent, Python-Skript, läuft unter dem eigenen Benutzerkonto ohne Adminrechte
Liest	eigenen Teams-Status, Zeiten und Frei/Gebucht des eigenen Kalenders, ob das Mikrofon benutzt wird, ob der Bildschirm gesperrt ist
Liest nicht	E-Mails, Dateien, Chats, Kontakte, Betreffs, Teilnehmer und Inhalte von Terminen, Audio
Schreibt	Terminbuchung (Kernfunktion): Termine im eigenen Kalender mit Einladung an den Besucher
Netzwerk	nur ausgehend HTTPS zu login.microsoftonline.com und graph.microsoft.com, kein offener Port
Rechte Microsoft 365	delegiert: Calendars.ReadBasic, Calendars.ReadWrite (Terminbuchung), Presence.Read, MailboxSettings.Read, einmalige Admin-Zustimmung
Gerät	Display per USB (nur COM-Port und JTAG des Displays), eigenes Einrichtungs-WLAN mit WPA2, abschaltbar
Gesamtrisiko	**gering** (Abschnitt 7)
Widerruf	jederzeit: Token löschen, Sitzungen in Entra widerrufen, Aufgabe entfernen